

Technical Project Report: Detection and Analysis of FTP Data Exfiltration Using 5-Tuple Correlation and Log Forensics in a Virtualized SOC Lab Environment, By Wisdom (CyberOps Associate).

1. Introduction

In this project, I created a virtualized SOC lab using Security Onion to simulate a data exfiltration scenario involving a compromised host. I detected and analyzed the attack using 5-tuple correlation, log forensics, and network packet inspection tools such as Sguil, Wireshark, and Kibana. The attacker used FTP to steal and delete a sensitive file, which I tracked through transcript analysis and Zeek logs. This hands-on experience helped me understand how data exfiltration attacks occur and how to investigate them using real-world SOC workflows.

2. Virtual Lab Environment Setup

Tool and Software

- Virtual Box (Oracle Box)
- CyberOps Security Union
- Ubuntu (64-bit) Operating System

2.1 – Review of already gathered Logs using Sguil.

ApplicationsPlacesSguil.tk

Sat 15:58

SGUIL-0.9.0 - Connected To localhost

FileQueryReportsSound: OffServerName: localhostUserName: analystUserID: 22025-05-24 15:58:55 GMT

RealTime EventsEscalated Events

ST	CNT	Sensor	Alert ID	Date/Time	Src IP	SPort	Dst IP	DPort	Pr	Event Message
RT	114	seconion-...	5.251	2019-07-19 18:57:23	172.16.4.205	49255	31.7.62.214	443	6	ET POLICY HTTP traffic on port
RT	2	seconion-...	5.365	2020-02-21 00:53:55	172.17.8.174	62362	172.17.8.8	53	17	ET POLICY DNS Update From E
RT	13	seconion-...	5.366	2020-02-21 00:55:07	49.51.172.56	80	172.17.8.174	49731	6	ET CURRENT_EVENTS Likely .
RT	13	seconion-...	5.379	2020-02-21 00:55:07	49.51.172.56	80	172.17.8.174	49731	6	ET CURRENT_EVENTS WinHtt.
RT	13	seconion-...	5.392	2020-02-21 00:55:07	49.51.172.56	80	172.17.8.174	49731	6	ET POLICY PE EXE or DLL Win
RT	4	seconion-...	5.406	2020-02-21 01:11:48	91.211.88.122	443	172.17.8.174	49760	6	ET TROJAN ABUSE.CH SSL BI
RT	1	seconion-...	5.1	2020-06-11 03:41:20	209.165.200.235	6200	209.165.201.17	45415	6	GPL ATTACK_RESPONSE id c.
RT	351	seconion-...	1.1	2020-06-19 18:09:28	0.0.0.0		0.0.0.0		0	[OSSEC] File added to the syste
RT	23	seconion-...	1.2	2020-06-19 18:09:29	0.0.0.0		0.0.0.0		0	[OSSEC] Integrity checksum ch.
RT	7	seconion-...	1.4	2020-06-19 18:10:04	0.0.0.0		0.0.0.0		0	[OSSEC] New group added to th
RT	7	seconion-...	1.5	2020-06-19 18:10:04	0.0.0.0		0.0.0.0		0	[OSSEC] New user added to the
RT	2	seconion-...	1.18	2020-06-19 18:14:41	0.0.0.0		0.0.0.0		0	[OSSEC] Listened ports status (
RT	1	seconion-...	1.19	2020-06-19 18:18:41	0.0.0.0		0.0.0.0		0	[OSSEC] Received 0 packets in

IP ResolutionAgent StatusSnort StatisticsSystem Msg

☐ Reverse DNS☒ Enable External DNS

Src IP:
Src Name:

Dst IP:
Dst Name:

Whois Query: ☒ None ☐ Src IP ☐ Dst IP

☐ Show Packet Data☐ Show Rule

IP	Source IP	Dest IP	Ver	HL	TOS	len	ID	Flags	Offset	TTL	chkSum
TCP	Source Port	Dest Port	RRRCSSYI	Seq #	Ack #	Offset	Res	Window	Urp	ChkSum	
DATA											

Search Packet Payload☐ Hex☒ Text☐ NoCase

SGUIL-0.9.0 - Connected To localh...1 / 4

I identified Alert ID 5.1 as suspicious because the alert message showed root access was returned, the IP communication looked unusual, the alert type indicated an attack response, and the behavior didn't match normal network activity.

2.1.1 – Validating Alert Authenticity Through Packet and Rule Analysis.

By checking the show packet data and show rule boxes in Sguil

The screenshot displays the Sguil interface, which is connected to localhost. The top bar shows the date and time as Sun 01:20. The main window is divided into two sections: a list of alerts on the left and a detailed packet analysis on the right.

Alert List:

ST	CNT	Sensor	Alert ID	Date/Time	Src IP	SPort	Dst IP	DPort	Pr	Event Message
RT	2	seconion...	5.1171	2019-04-15 16:44:18	10.0.90.175	56765	208.67.222.222	53	17	ET POLICY External IP Lookup Domain (myip.opendns.com in DNS lookup)
RT	7	seconion...	5.1175	2019-04-15 21:25:18	10.0.90.175	49351	85.114.134.49	80	6	ET INFO GENERIC SUSPICIOUS POST to Dotted Quad with Fake Browser 1
RT	1	seconion...	5.233	2019-07-19 18:52:36	172.16.4.205	51992	172.16.4.4	53	17	ET POLICY DNS Update From External net
RT	17	seconion...	5.234	2019-07-19 18:53:12	172.16.4.205	49249	185.243.115.84	80	6	ET POLICY Data POST to an image file (gif)
RT	114	seconion...	5.251	2019-07-19 18:57:23	172.16.4.205	49255	31.7.62.214	443	6	ET POLICY HTTP traffic on port 443 (POST)
RT	2	seconion...	5.365	2020-02-21 00:55:55	172.17.8.174	62362	172.17.8.8	53	17	ET POLICY DNS Update From External net
RT	13	seconion...	5.366	2020-02-21 00:55:07	49.51.172.56	80	172.17.8.174	49731	6	ET CURRENT_EVENTS Likely Evil EXE download from WinHttpRequest non-exe extension
RT	13	seconion...	5.379	2020-02-21 00:55:07	49.51.172.56	80	172.17.8.174	49731	6	ET CURRENT_EVENTS WinHttpRequest Downloading EXE
RT	13	seconion...	5.392	2020-02-21 00:55:07	49.51.172.56	80	172.17.8.174	49731	6	ET POLICY PE EXE or DLL Windows file download HTTP
RT	4	seconion...	5.406	2020-02-21 01:11:48	91.211.88.122	443	172.17.8.174	49760	6	ET TROJAN ABUSE.CH SSL Blacklist Malicious SSL certificate detected (Dridex)
RT	1	seconion...	5.1	2020-06-11 03:41:20	209.165.200.235	6200	209.165.201.17	45415	6	GPL ATTACK_RESPONSE id check returned root
RT	351	seconion...	1.1	2020-06-19 18:09:28	0.0.0.0	0.0.0.0	0.0.0.0	0	0	[OSSEC] File added to the system.
RT	23	seconion...	1.2	2020-06-19 18:09:29	0.0.0.0	0.0.0.0	0.0.0.0	0	0	[OSSEC] Integrity checksum changed.
RT	7	seconion...	1.4	2020-06-19 18:10:04	0.0.0.0	0.0.0.0	0.0.0.0	0	0	[OSSEC] New group added to the system
RT	7	seconion...	1.5	2020-06-19 18:10:04	0.0.0.0	0.0.0.0	0.0.0.0	0	0	[OSSEC] New user added to the system
RT	2	seconion...	1.18	2020-06-19 18:14:41	0.0.0.0	0.0.0.0	0.0.0.0	0	0	[OSSEC] Listened ports status (netstat) changed (new port opened or closed).
RT	1	seconion...	1.19	2020-06-19 18:18:41	0.0.0.0	0.0.0.0	0.0.0.0	0	0	[OSSEC] Received 0 packets in designated time interval (defined in ossec.conf). Please check interface, cabling, and tap/span!

Packet Analysis (Alert ID 5.1):

Alert ID: 5.1
Alert Message: GPL ATTACK_RESPONSE id check returned root
Content: uid=0|28|root|29|; fast_pattern:only; classtype:bad-unknown; sid:210498; rev:8; metadata:created_at 2010_09_23, updated_at 2010_09_23; /nsm/server_data/securityonion/rules/seconion-import-1/downloaded.rules: Line 700

IP	Source IP	Dest IP	Ver	HL	TOS	len	ID	Flags	Offset	TTL	ChkSum
209.165.200.235	209.165.201.17	4	5	0	76	31846	2	0	64	35069	

TCP Analysis:

Source Port	Dest Port	R	R	U	A	P	R	S	F	Seq #	Ack #	Offset	Res	Window	Urp	ChkSum
6200	45415	.	.	.	X	X	.	.	.	2951186435	1436935650	8	0	181	0	29271

DATA Section:

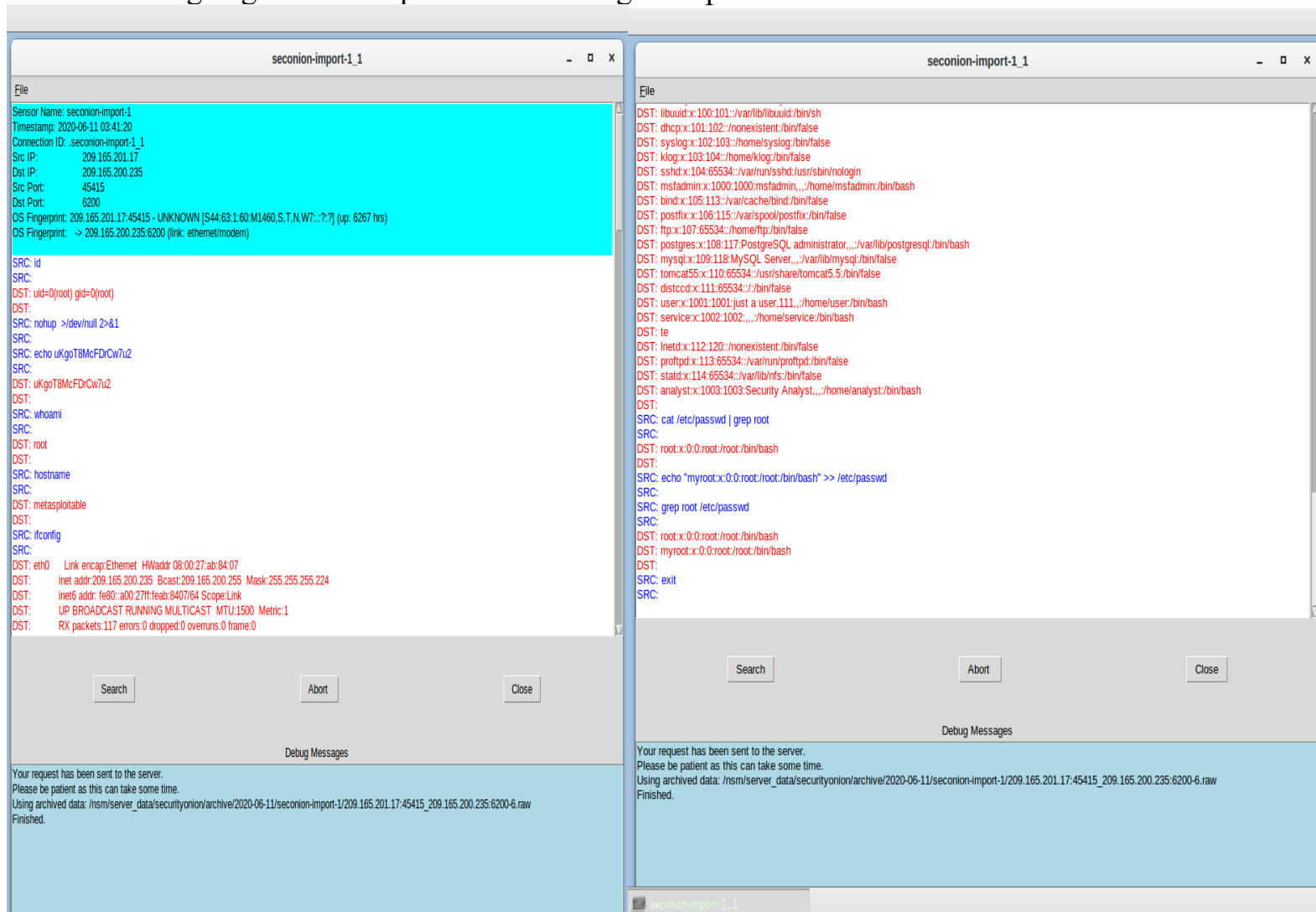
75 69 64 3D 30 28 72 6F 6F 74 29 6A uid=0(root) gid=0(root).

30 28 72 6F 6F 74 29 6A

Using Sguil's show packet and show rule features, I identified suspicious traffic between two hosts source (209.165.200.235) and destination (209.165.201.17) on ports 6200 and 45415. The IDS flagged data containing uid=0|28|root|29| and packet data section with uid=0(root) gid=0(root) indicate root user activity. This confirmed a real security breach not a false alarm. Also, the class type of this breach is bad-unknown with Signature ID that triggered the alert 2101498. This called for more analysis and insight.

2.1.2 - Transcript Analysis: Command-Based Attack Interaction Between Threat Actor and Compromised Host.

Using Seguil Transcript view to investigate exploit activities



The attacker IP: 209.165.201.17 remotely compromised the victim host 209.165.200.235 and gained root access, confirmed via `id`, `whoami`, and `hostname` commands (host: `metasploitable`). They used `ifconfig` to probe network details and exfiltrated sensitive data using `cat /etc/shadow` and `cat /etc/passwd`. A hidden user `myroot` was created to maintain persistent access. The command `echo uKgoT8McFDrCw7u2` marked the attacker's presence.

To further analyze potential credential use and data movement, I pivoted to Wireshark for a deep packet inspection.

2.2 - Wireshark Analysis: Validating the Attack via TCP Stream Forensics

I pivoted the suspicious log alert 5.1 in Wireshark to perform deep packet inspection.

Applications Places Wireshark Thu 09:16

209.165.201.17_45415_209.165.200.235_6200-6.raw

File Edit View Go Capture Analyze Statistics Telephony Wireless Tools Help

Apply a display filter ... <Ctrl-/> Expression...

No.	Time	Source	Destination	Protocol	Length	Host	Host	Info
1	2020-06-11 03:41:20...	209.165.201.17	209.165.200.235	TCP	74	209.165.201.17	209.165.200.235	45415 → 6200 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM=1 TSval=2256140987 TSecr=0 WS=128
2	2020-06-11 03:41:20...	209.165.200.235	209.165.201.17	TCP	74	209.165.200.235	209.165.201.17	6200 → 45415 [SYN, ACK] Seq=0 Ack=1 Win=5792 Len=0 MSS=1460 SACK_PERM=1 TSval=586854 TSecr=2256140987 WS=32
3	2020-06-11 03:41:20...	209.165.201.17	209.165.200.235	TCP	66	209.165.201.17	209.165.200.235	45415 → 6200 [ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=2256140988 TSecr=586854
4	2020-06-11 03:41:20...	209.165.201.17	209.165.200.235	TCP	69	209.165.201.17	209.165.200.235	45415 → 6200 [PSH, ACK] Seq=1 Ack=1 Win=64256 Len=3 TSval=2256140988 TSecr=586854
5	2020-06-11 03:41:20...	209.165.200.235	209.165.201.17	TCP	66	209.165.200.235	209.165.201.17	6200 → 45415 [ACK] Seq=1 Ack=4 Win=5792 Len=0 TSval=586854 TSecr=2256140988
6	2020-06-11 03:41:20...	209.165.200.235	209.165.201.17	TCP	90	209.165.200.235	209.165.201.17	6200 → 45415 [PSH, ACK] Seq=1 Ack=4 Win=5792 Len=24 TSval=586854 TSecr=2256140988
7	2020-06-11 03:41:20...	209.165.201.17	209.165.200.235	TCP	66	209.165.201.17	209.165.200.235	45415 → 6200 [ACK] Seq=4 Ack=25 Win=64256 Len=0 TSval=2256140990 TSecr=586854
8	2020-06-11 03:41:20...	209.165.201.17	209.165.200.235	TCP	88	209.165.201.17	209.165.200.235	45415 → 6200 [PSH, ACK] Seq=4 Ack=25 Win=64256 Len=22 TSval=2256140990 TSecr=586854
9	2020-06-11 03:41:20...	209.165.200.235	209.165.201.17	TCP	66	209.165.200.235	209.165.201.17	6200 → 45415 [ACK] Seq=25 Ack=26 Win=5792 Len=0 TSval=586858 TSecr=2256140990
10	2020-06-11 03:41:24...	209.165.201.17	209.165.200.235	TCP	89	209.165.201.17	209.165.200.235	45415 → 6200 [PSH, ACK] Seq=26 Ack=25 Win=64256 Len=23 TSval=2256144594 TSecr=586858
11	2020-06-11 03:41:24...	209.165.200.235	209.165.201.17	TCP	66	209.165.200.235	209.165.201.17	6200 → 45415 [ACK] Seq=25 Ack=49 Win=5792 Len=0 TSval=587215 TSecr=2256144594
12	2020-06-11 03:41:24...	209.165.200.235	209.165.201.17	TCP	83	209.165.200.235	209.165.201.17	6200 → 45415 [PSH, ACK] Seq=25 Ack=49 Win=5792 Len=17 TSval=587215 TSecr=2256144594
13	2020-06-11 03:41:24...	209.165.201.17	209.165.200.235	TCP	66	209.165.201.17	209.165.200.235	45415 → 6200 [ACK] Seq=49 Ack=42 Win=64256 Len=0 TSval=2256144596 TSecr=587215
14	2020-06-11 03:41:50...	209.165.201.17	209.165.200.235	TCP	73	209.165.201.17	209.165.200.235	45415 → 6200 [PSH, ACK] Seq=49 Ack=42 Win=64256 Len=7 TSval=2256171013 TSecr=587215
15	2020-06-11 03:41:50...	209.165.200.235	209.165.201.17	TCP	71	209.165.200.235	209.165.201.17	6200 → 45415 [PSH, ACK] Seq=42 Ack=56 Win=5792 Len=5 TSval=589859 TSecr=2256171013
16	2020-06-11 03:41:50...	209.165.201.17	209.165.200.235	TCP	66	209.165.201.17	209.165.200.235	45415 → 6200 [ACK] Seq=56 Ack=47 Win=64256 Len=0 TSval=2256171015 TSecr=589859
17	2020-06-11 03:41:53...	209.165.201.17	209.165.200.235	TCP	75	209.165.201.17	209.165.200.235	45415 → 6200 [PSH, ACK] Seq=56 Ack=47 Win=64256 Len=9 TSval=2256173715 TSecr=589859
18	2020-06-11 03:41:53...	209.165.200.235	209.165.201.17	TCP	81	209.165.200.235	209.165.201.17	6200 → 45415 [PSH, ACK] Seq=47 Ack=65 Win=5792 Len=15 TSval=590130 TSecr=2256173715
19	2020-06-11 03:41:53...	209.165.201.17	209.165.200.235	TCP	66	209.165.201.17	209.165.200.235	45415 → 6200 [ACK] Seq=65 Ack=62 Win=64256 Len=0 TSval=2256173716 TSecr=590130
20	2020-06-11 03:41:56...	209.165.201.17	209.165.200.235	TCP	75	209.165.201.17	209.165.200.235	45415 → 6200 [PSH, ACK] Seq=65 Ack=62 Win=64256 Len=9 TSval=2256176530 TSecr=590130
21	2020-06-11 03:41:56...	209.165.200.235	209.165.201.17	TCP	1008	209.165.200.235	209.165.201.17	6200 → 45415 [PSH, ACK] Seq=62 Ack=74 Win=5792 Len=942 TSval=590411 TSecr=2256176530

Frame 1: 74 bytes on wire (592 bits), 74 bytes captured (592 bits)
Ethernet II, Src: 08:50:56:b3:72:09, Dst: 08:00:27:ab:84:07
Internet Protocol Version 4, Src: 209.165.201.17, Dst: 209.165.200.235
Transmission Control Protocol, Src Port: 45415, Dst Port: 6200, Seq: 0, Len: 0
Source Port: 45415
Destination Port: 6200
[Stream index: 0]
[TCP Segment Len: 0]
Sequence number: 0 (relative sequence number)
[Next sequence number: 0 (relative sequence number)]
Acknowledgment number: 0
1010 = Header Length: 40 bytes (10)
Flags: 0x002 (SYN)
Window size value: 64240
[Calculated window size: 64240]
Checksum: 0x916d [unverified]
[Checksum Status: Unverified]
Urgent pointer: 0
Options: (20 bytes), Maximum segment size, SACK permitted, Timestamps, No-Operation (NOP), Window scale
[Timestamps]

209.165.201.17_45415_209.165.200.235_6200-6.raw Packets: 49 - Displayed: 49 (100.0%) Profile: Default

[SGUIL-0.9.0 - Connected To localh...] [seconion-import-1.1]

FRAME 47

Frame 47: 66 bytes on wire (528 bits), 66 bytes captured (528 bits)
Ethernet II, Src: 08:00:27:ab:84:07, Dst: 00:50:56:b3:72:09
Internet Protocol Version 4, Src: 209.165.200.235, Dst: 209.165.201.17
Transmission Control Protocol, Src Port: 6200, Dst Port: 45415, Seq: 4102, Ack: 288, Len: 0
Source Port: 6200
Destination Port: 45415
[Stream index: 0]
[TCP Segment Len: 0]
Sequence number: 4102 (relative sequence number)
[Next sequence number: 4102 (relative sequence number)]
Acknowledgment number: 288 (relative ack number)
1000 = Header Length: 32 bytes (8)
Flags: 0x011 (FIN, ACK)
Window size value: 181
[Calculated window size: 5792]
[Window size scaling factor: 32]
Checksum: 0x5fb4 [unverified]
[Checksum Status: Unverified]
Urgent pointer: 0
Options: (12 bytes), No-Operation (NOP), No-Operation (NOP), Timestamps
[SEQ/ACK analysis]
[This is an ACK to the segment in frame: 46]
[The RTT to ACK the segment was 0.001465000 seconds]

FRAME 49

Frame 49: 66 bytes on wire (528 bits), 66 bytes captured (528 bits)
Ethernet II, Src: 08:00:27:ab:84:07, Dst: 00:50:56:b3:72:09
Internet Protocol Version 4, Src: 209.165.200.235, Dst: 209.165.201.17
Transmission Control Protocol, Src Port: 6200, Dst Port: 45415, Seq: 4103, Ack: 289, Len: 0
Source Port: 6200
Destination Port: 45415
[Stream index: 0]
[TCP Segment Len: 0]
Sequence number: 4103 (relative sequence number)
[Next sequence number: 4103 (relative sequence number)]
Acknowledgment number: 289 (relative ack number)
1000 = Header Length: 32 bytes (8)
Flags: 0x010 (ACK)
Window size value: 181
[Calculated window size: 5792]
[Window size scaling factor: 32]
Checksum: 0x5fb1 [unverified]
[Checksum Status: Unverified]
Urgent pointer: 0
Options: (12 bytes), No-Operation (NOP), No-Operation (NOP), Timestamps
[SEQ/ACK analysis]
[This is an ACK to the segment in frame: 48]
[The RTT to ACK the segment was 0.000940000 seconds]

The attacker, with the IP address 209.165.201.17, tries to connect to the victim's computer at 209.165.200.235 using a special, unusual port (6200) that's often used for secret or unauthorized access. This starts with a SYN packet (Frame 1) from source port 45415, and includes TCP options like timestamping and window scaling, indicating a well-structured, possibly tool-generated session. Subsequent packets contain PSH, ACK flags with small to mid-sized payloads often a sign of interactive shell use, especially when accompanied by a clean FIN, ACK termination sequence (Frames 47 & 49). The stable sequence and acknowledgment numbers suggest ordered command-response traffic. Overall, the way the connection is set up and used suggests this is a deliberate, tool-based attack trying to control the victim's machine remotely.

These TCP characteristics, high port access, controlled flags, window negotiation, and structured teardown provide strong justification to pivot into TCP stream analysis to inspect the full content of the session.

2.2.1 - Reconstructing Attacker Session via TCP Stream Analysis

Followed the TCP stream in Wireshark to trace the attacker's commands and responses during the session that was able to travel over the network.

The image displays two side-by-side screenshots of the Wireshark network protocol analyzer, showing the reconstruction of a TCP stream from a captured packet capture file.

Left Screenshot: The "Follow TCP Stream" window is open, showing the packet list and packet details. The packet list shows the initial SYN packet (Frame 1) and subsequent packets. The packet details pane shows the "Ethernet II" and "Internet Protocol Version 4" fields, indicating the source and destination IP addresses and ports.

Right Screenshot: The "Follow TCP Stream" window is open, showing the packet bytes pane. The packet bytes pane displays the reconstructed TCP stream content, which includes a list of system paths and a series of commands executed by the attacker. The commands are as follows:

```
man:x:6:12:man:/var/cache/man:/bin/sh
lp:x:7:7:lp:/var/spool/lpd:/bin/sh
mail:x:8:8:mail:/var/mail:/bin/sh
news:x:9:9:news:/var/spool/news:/bin/sh
uucp:x:10:10:uucp:/var/spool/uucp:/bin/sh
proxy:x:13:13:proxy:/bin:/bin/sh
www-data:x:33:33:www-data:/var/www:/bin/sh
backup:x:34:34:backup:/var/backups:/bin/sh
list:x:38:38:Mailing List Manager:/var/list:/bin/sh
irc:x:39:39:ircd:/var/run/ircd:/bin/sh
gnats:x:41:41:Gnats Bug-Reporting System (admin)/var/lib/gnats:/bin/sh
nobody:x:65534:65534:nobody:/nonexistent:/bin/sh
libuid:x:100:101:/var/lib/libuid:/bin/sh
dhcp:x:101:102:/nonexistent:/bin/false
syslog:x:102:103:/home/syslog:/bin/false
klog:x:103:104:/home/klog:/bin/false
sshd:x:104:65534:/var/run/sshd:/usr/sbin/nologin
msfadmin:x:1000:1000:msfadmin,,/home/msfadmin:/bin/bash
bind:x:105:113:/var/cache/bind:/bin/false
postfix:x:106:115:/var/spool/postfix:/bin/false
ftp:x:107:65534:/home/ftp:/bin/false
postgres:x:108:117:PostgreSQL administrator,,/var/lib/postgresql:/bin/bash
mysql:x:109:118:MySQL Server,,/var/lib/mysql:/bin/false
tomcat55:x:110:65534:/usr/share/tomcat5.5:/bin/false
distccd:x:111:65534:/bin/false
user:x:1001:1001:just a user,111,,/home/user:/bin/bash
service:x:1002:1002,,/home/service:/bin/bash
telnetd:x:112:120:/nonexistent:/bin/false
proftpd:x:113:65534:/var/run/proftpd:/bin/false
statd:x:114:65534:/var/lib/nfs:/bin/false
analyst:x:1003:1003:Security Analyst,,/home/analyst:/bin/bash
cat /etc/passwd | grep root
root:x:0:0:root:/root:/bin/bash
echo "myroot:x:0:0:root:/root:/bin/bash" >> /etc/passwd
grep root /etc/passwd
root:x:0:0:root:/root:/bin/bash
myroot:x:0:0:root:/root:/bin/bash
exit
```

The bottom of the right screenshot shows the "Packet 33. 14 client pkts, 11 server pkts, 20 turns. Click to select." and the "Entire conversation (4,388 bytes)" pane, which displays the reconstructed TCP stream content in ASCII format.

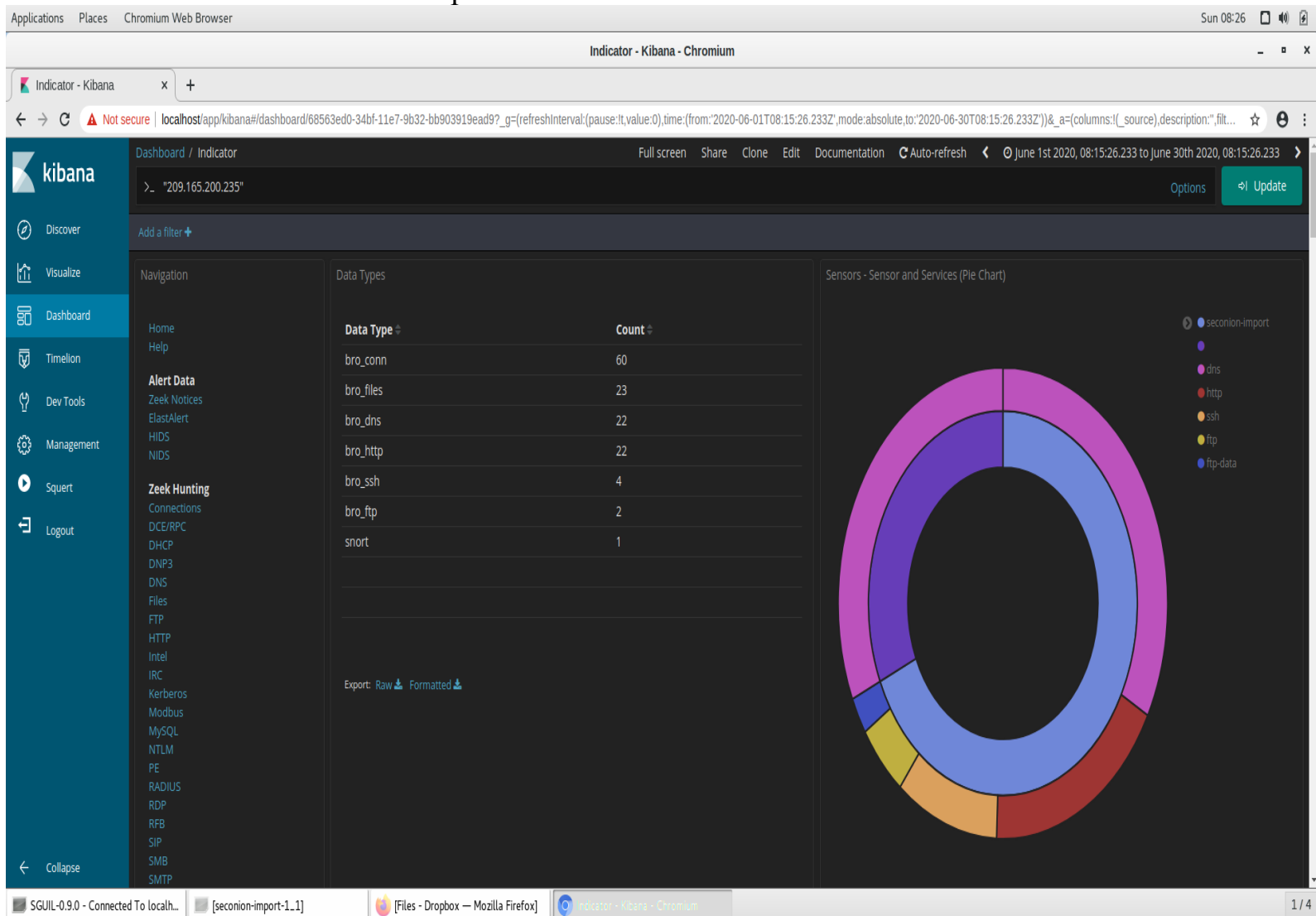
The TCP stream confirms that the attacker gained root-level access to the victim host (metasploitable), as shown by successful execution of `id`, `whoami`, and `hostname`. System reconnaissance followed (`ifconfig`), along with critical data exposure using `cat /etc/shadow` and `cat /etc/passwd`, revealing password hashes and user account

details. The attacker then created a persistent backdoor account named myroot with root privileges by editing both authentication files.

The session ended with a clean exit, suggesting deliberate and controlled activity. Further investigation is needed to determine how the attacker used the stolen credentials and root privileges

2.3 - Correlating Network Activity and Exfiltration Evidence in Kibana.

With root-level access confirmed through the TCP stream, the next step is to pivot alert ID 5.1 to Kibana to correlate logs and uncover what actions were taken on the network after initial compromise.



It was established from Wireshark that the timestamp of the attack is June 11, 2020. Therefore, the dashboard has been configured to cover logs from June 1, 2020, to June 30, 2020, for further analysis. Since the dashboard is customized to reflect the time the attack occurred, I focused on reviewing protocol entries under the *Service* and *Sensor* pie charts. Under the data types bro_ssh and bro_ftp, I noticed unusual activity.

2.3.1 – SSH Log Analysis – Confirmed Remote Access and Compromise

The bro_ssh log confirms a successful SSH connection from 209.165.201.17 (running OpenSSH_7.4p1 on Debian-10) to 209.165.200.235 (OpenSSH_4.7p1 on Debian-8ubuntu1) over port 22, with the attacker initiating the session from source port 43996. This validates that a remote login was established, aligning with earlier findings from the transcript and Wireshark analysis that revealed command execution such as id and cat /etc/shadow. Together, this solidifies evidence of unauthorized root-level access via SSH, confirming the attacker's direct interaction with the compromised host.

capME! - Chromium

Zeek - DNS - Kibana

zXIBB6Cd_OSZvhc

close

209.165.201.17:46448_209.165.200.235:22-6-1172876996.pcap

Log entry:
{"ts":"2020-06-11T03:47:30.968580Z","uid":"C7cnK449sB2F5ZHXVd","id.orig_h":"209.165.201.17","id.orig_p":46448,"id.resp_h":"209.165.200.235","id.resp_p":22,"version":2,"auth_success":true,"auth_attempts":1,"client":"SSH-2.0-OpenSSH_8.1p1 Debian-5","server":"SSH-2.0-OpenSSH_4.7p1 Debian-8ubuntu1","cipher_alg":"aes128-ctr","mac_alg":"umac-64@openssh.com","compression_alg":"none","kex_alg":"diffie-hellman-group-exchange-sha256","host_key_alg":"ssh-rsa","host_key":"56:56:24:0f:21:1d:de:a7:2b:ae:61:b1:24:3d:e8:f3","hashVersion":"1.0","hash":"ec7378c1a92f5a8dde7e8b7a1ddf33d1","hashServer":"2270b0152ebe5afb20df3041c7f076a2","cshka":"rsa-sha2-512-cert-v01@openssh.com,rsa-sha2-256-cert-v01@openssh.com,ssh-rsa-cert-v01@openssh.com,rsa-sha2-512,rsa-sha2-256,ssh-rsa,ecdsa-sha2-nistp256-cert-v01@openssh.com,ecdsa-sha2-nistp384-cert-v01@openssh.com,ecdsa-sha2-nistp521-cert-v01@openssh.com,ssh-ed25519-cert-v01@openssh.com,ecdsa-sha2-nistp256,ecdsa-sha2-nistp384,ecdsa-sha2-nistp521,ssh-ed25519","hashAlgorithms":"curve25519-sha256,curve25519-sha256@libssh.org,ecdh-sha2-nistp256,ecdh-sha2-nistp384,ecdh-sha2-nistp521,diffie-hellman-group-exchange-sha256,diffie-hellman-group16-sha512,diffie-hellman-group18-sha512,diffie-hellman-group14-sha256,diffie-hellman-group14-sha1,ext-info-c:chacha20-poly1305@openssh.com,aes128-ctr,aes192-ctr,aes256-ctr,aes128-gcm@openssh.com,aes256-gcm@openssh.com,umac-64-etm@openssh.com,umac-128-etm@openssh.com,hmac-sha2-256-etm@openssh.com,hmac-sha2-512-etm@openssh.com,hmac-sha1-etm@openssh.com,umac-64@openssh.com,umac-128@openssh.com,hmac-sha2-256,hmac-sha2-512,hmac-sha1:none,zlib@openssh.com,zlib","sshk":"ssh-rsa,ssh-dss","hashServerAlgorithms":"diffie-hellman-group-exchange-sha256,diffie-hellman-group-exchange-sha1,diffie-hellman-group14-sha1,diffie-hellman-group1-sha1,aes128-cbc,3des-cbc,blowfish-cbc,cast128-cbc,arcfour128,arcfour256,arcfour,aes192-cbc,aes256-cbc,rijndael-cbc@lysator.liu.se,aes128-ctr,aes192-ctr,aes256-ctr,umac-64@openssh.com,hmac-ripemd160,hmac-ripemd160@openssh.com,hmac-sha1-96,hmac-md5-96,hmac-md5,hmac-sha1,umac-64@openssh.com,hmac-ripemd160,hmac-ripemd160@openssh.com,hmac-sha1-96,hmac-md5-96:none,zlib@openssh.com")

Sensor Name: seconion-import

Timestamp: 2020-06-11 03:47:30

Connection ID: CLI

Src IP: 209.165.201.17

Dst IP: 209.165.200.235

Src Port: 46448

Dst Port: 22

OS Fingerprint: 209.165.201.17:46448 - UNKNOWN [S44:63:1:60:M1460,S,T,N,W7::?:?] (up: 6268 hrs)

OS Fingerprint: -> 209.165.200.235:22 (link: ethernet/modem)

SRC: SSH-2.0-OpenSSH_8.1p1 Debian-5

SRC:

DST: SSH-2.0-OpenSSH_4.7p1 Debian-8ubuntu1

DST:

DST:

DST:YC(/J.....

DST:-diffie-hellman-group-exchange-sha256,diffie-hellman-group-exchange-sha1,diffie-hellman-group14-sha1,diffie-hellman-group1-sha1....ssh-rsa,ssh-dss....aes128-cbc,3des-cbc,blowfish-cbc,cast128-cbc,arcfour128,arcfour256,arcfour,aes192-cbc,aes256-cbc,rijndael-cbc@lysator.liu.se,aes128-ctr,aes192-ctr,aes256-ctr....aes128-cbc,3des-cbc,blowfish-cbc,cast128-cbc,arcfour128,arcfour256,arcfour,aes192-cbc,aes256-cbc,rijndael-cbc@lysator.liu.se,aes128-ctr,aes192-ctr,aes256-ctr....hmac-sha1,umac-64@openssh.com,hmac-ripemd160,hmac-ripemd160@openssh.com,hmac-sha1-96,hmac-md5-96....hmac-md5,hmac-sha1,umac-64@openssh.com,hmac-ripemd160,hmac-ripemd160@openssh.com,hmac-sha1-96,hmac-md5-96....none,zlib@openssh.com,....none,zlib@openssh.com,.....

SRC:J#..H.....J7.....

SRC: curve25519-sha256,curve25519-sha256@libssh.org,ecdh-sha2-nistp256,ecdh-sha2-nistp384,ecdh-sha2-nistp521,diffie-hellman-group-exchange-sha256,diffie-hellman-group16-sha512,diffie-hellman-group18-sha512,diffie-hellman-group14-sha256,diffie-hellman-group14-sha1,ext-info-c:..rsa-sha2-512-cert-v01@openssh.com,rsa-sha2-256-cert-v01@openssh.com,ssh-rsa-cert-v01@openssh.com,ssh-rsa,ecdsa-sha2-nistp256-cert-v01@openssh.com,ecdsa-sha2-nistp384-cert-v01@openssh.com,ecdsa-sha2-nistp521-cert-v01@openssh.com,ssh-ed25519-cert-v01@openssh.com,ecdsa-sha2-nistp256,ecdsa-sha2-nistp384,ecdsa-sha2-nistp521,ssh-ed25519....lchacha20-poly1305@openssh.com,aes128-ctr,aes192-ctr,aes256-ctr,aes128-gcm@openssh.com,aes256-gcm@openssh.com....umac-64-etm@openssh.com,umac-128-etm@openssh.com,hmac-sha2-256-etm@openssh.com,hmac-sha2-512-etm@openssh.com,hmac-sha1-etm@openssh.com,umac-64@openssh.com,umac-128@openssh.com,hmac-sha2-256,hmac-sha2-512,hmac-sha1....umac-64-etm@openssh.com,umac-128-etm@openssh.com,hmac-sha2-256-etm@openssh.com,hmac-sha2-512-etm@openssh.com,hmac-sha1-etm@openssh.com,umac-64@openssh.com

2.3.2 – Identifying Data Exfiltration via FTP Protocol Analysis.

From the kibana dashboard, it confirmed we have two entries listed under FTP.

Time	source_ip	source_port	destination_ip	destination_port	id
June 11th 2020, 03:53:09.086	192.168.0.11	52776	209.165.200.235	21	LDjpxzIBB6Cd_OSZvhc
June 11th 2020, 03:53:09.086	192.168.0.11	52776	209.165.200.235	21	LTjpxzIBB6Cd_OSZvhc

The marked entry contains character combinations of STOR, TRANSFER COMPLETE, confidential.txt. This needs to be investigated further.

The screenshot shows the Kibana Overview dashboard in a Chromium browser. The left sidebar contains navigation links: Discover, Visualize, Dashboard, Timelion, Dev Tools, Management, Squert, and Logout. The main content area displays a list of log entries. The entry for 'message' is highlighted with a red box. The 'message' field contains a JSON object with details about an FTP event, including timestamps, user information, and the command 'STOR' for uploading 'confidential.txt'.

Field	Value
t _type	doc
t destination_geo.city_name	Monterey
t destination_geo.country_name	United States
t destination_geo.ip	209.165.200.235
t destination_geo.location	{ "lon": -121.8406, "lat": 36.3699 }
t destination_geo.region_code	US-CA
t destination_geo.region_name	California
t destination_geo.timezone	America/Los_Angeles
t destination_ip	209.165.200.235
t destination_ips	209.165.200.235
# destination_port	21
t event_type	bro_ftp
t ftp_argument	ftp://209.165.200.235/./confidential.txt
t ftp_command	STOR
t fluid	FX11V63eSMAE1N16S2
t host	d68c9360b6ae
t ips	209.165.200.235, 192.168.0.11
t message	{ "ts": "2020-06-11T03:53:09.086840Z", "uid": "C56keA4t8oXZdwTPR6", "id.orig_h": "192.168.0.11", "id.orig_p": 52776, "id.resp_h": "209.165.200.235", "id.resp_p": 21, "user": "analyst", "password": "<hidden>", "command": "STOR", "arg": "ftp://209.165.200.235/./confidential.txt", "mime_type": "text/plain", "reply_code": 226, "reply_msg": "Transfer complete.", "fluid": "FX11V63eSMAE1N16S2" }
t minetype	text/plain
t password	<hidden>
t path	/nsm/import/bro/bro-sak0dUdf/ftp.log
t reply_code	226
t reply_message	Transfer complete.

The log confirms that confidential.txt was uploaded from internal host 192.168.0.11 to the compromised machine 209.165.200.235 via FTP (port 21) using the STOR command. The event type is bro_ftp, and the action was performed under the analyst FTP account.

Since 192.168.0.11 is a private/internal IP, it cannot be accessed from outside, suggesting that the attacker used the compromised host which already had root access and a myroot backdoor user to access internal resources and store the sensitive file locally, staging it for later exfiltration.


```
capME! - Chromium
qzXIBB6Cd-_0SbfgO
close

192.168.0.11:52776_209.165.200.235:21-6-516940752.pcap

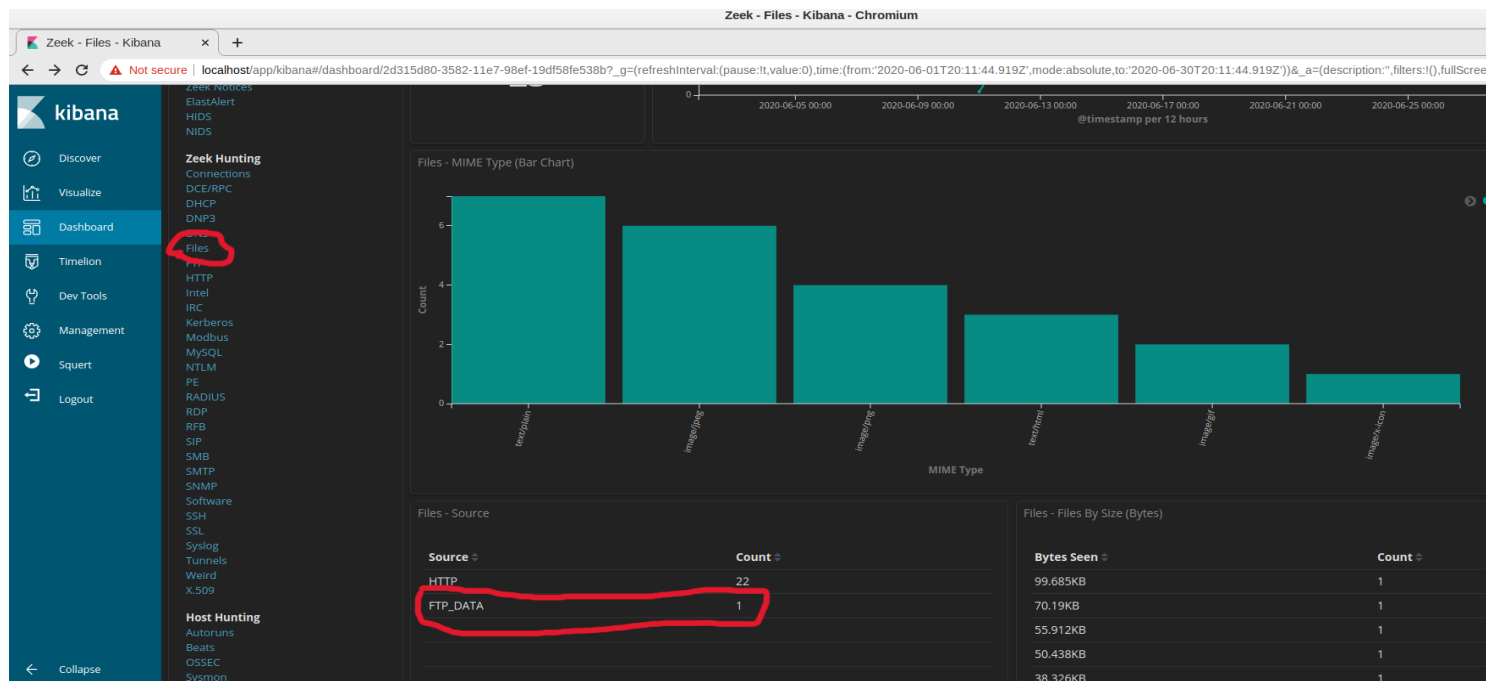
Log entry:
{"ts":"2020-06-11T03:53:09.086840Z","uid":"C5GkeA48oXZdWTPr6","id.orig_h":"192.168.0.11","id.orig_p":52776,"id.resp_h":"209.165.200.235","id.resp_p":21,"user":"analyst","password":"<hidden>","command":"STOR","arg":"ftp://209.165.200.235/./confidential.txt","mime_type":"text/plain","reply_code":226,"reply_msg":"Transfer complete.","tuid":"FX1V63eSMAEIN1652"}

Sensor Name: seconion-import
Timestamp: 2020-06-11 03:53:09
Connection ID: CLI
Src IP: 192.168.0.11
Dst IP: 209.165.200.235
Src Port: 52776
Dst Port: 21
OS Fingerprint: 192.168.0.11:52776 - UNKNOWN [S44:63:1:60:M1460,S,T,N,W7:??] (up: 3131 hrs)
OS Fingerprint -> 209.165.200.235:21 (link: ethernet/modem)
DST: 220 (vsFTPD 2.3.4)
DST:
SRC: USER analyst
SRC:
DST: 331 Please specify the password.
DST:
SRC: PASS cyberops
SRC:
DST: 230 Login successful.
DST:
SRC: SYST
SRC:
DST: 215 UNIX Type: L8
DST:
SRC: TYPE I
SRC:
DST: 200 Switching to Binary mode.
DST:
SRC: PORT 192.168.0.11,194.153
SRC:
DST: 200 PORT command successful. Consider using PASV.
DST:
SRC: STOR confidential.txt
SRC:
DST: 150 Ok to send data.
DST:
DST: 226 Transfer complete.
DST:
SRC: QUIT
SRC:
```

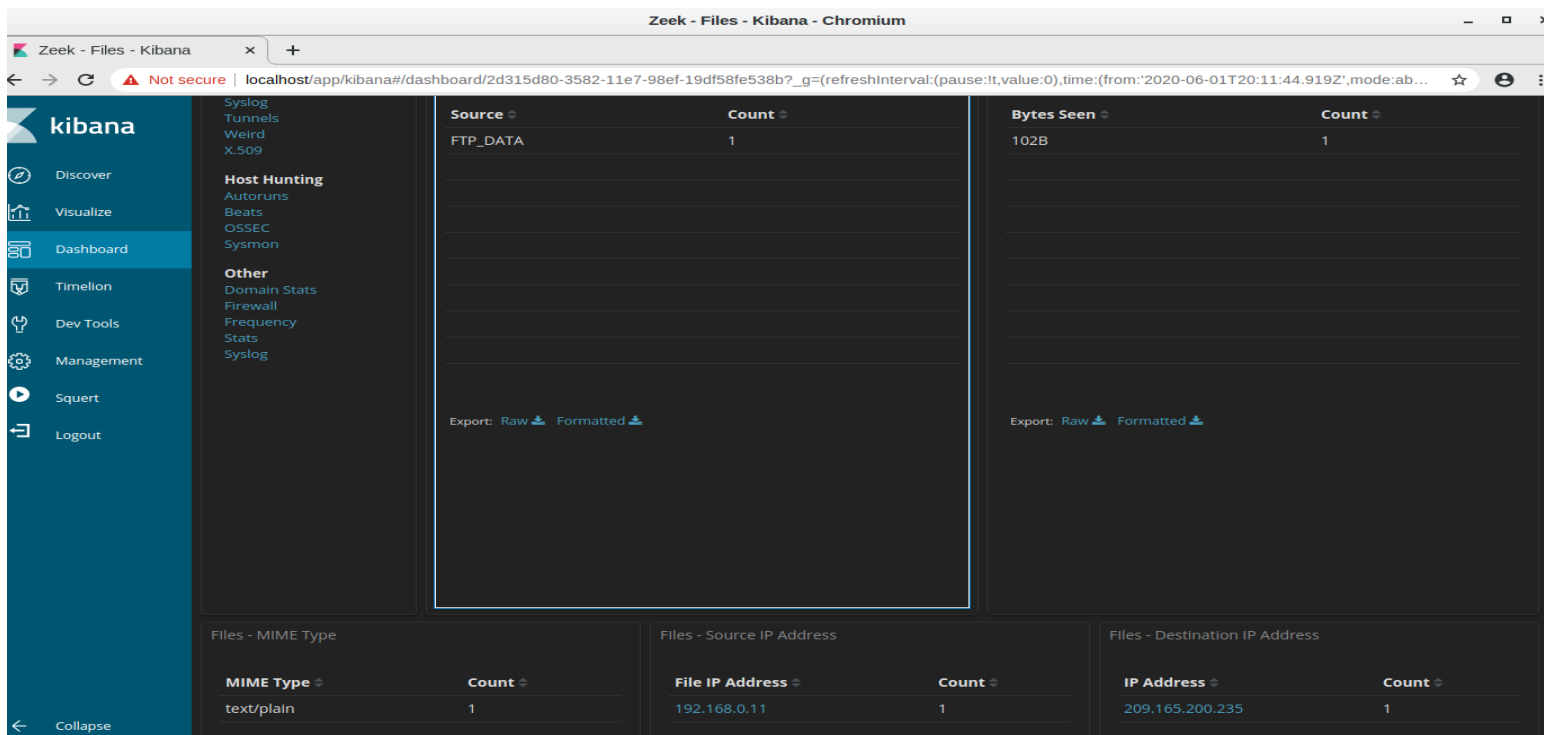
Accessed the FTP session transcript via the alert *id link* in Kibana, which opened CapMe. The transcript revealed a full FTP transaction where the attacker, using valid credentials (USER analyst, PASS CyberOps), connected to the server at 209.165.200.235 and executed the STOR command to transfer the file confidential.txt. The response 226 Transfer complete confirmed successful data exfiltration. I pivot to check Zeek file logs for full file transfer details.

2.3.2 - Analyzing Transferred File Metadata and payload via Zeek Hunting.

I navigated to the Zeek Hunting section and selected "Files" to review captured file activity. This revealed one FTP_DATA entry, confirming an FTP-based file transfer, along with 22 entries related to HTTP traffic.



I clicked on the FTP_DATA entry to view detailed metadata, including the file's MIME type, size, and the source and destination IP addresses involved in the transfer.



The screenshot shows the Zeek Files Kibana dashboard. The main table has columns for Source, Count, Bytes Seen, and Count. The first row shows FTP_DATA with a count of 1 and 102B bytes seen. Below the table, there are three smaller tables: Files - MIME Type, Files - Source IP Address, and Files - Destination IP Address. The MIME Type table shows text/plain with a count of 1. The Source IP Address table shows 192.168.0.11 with a count of 1. The Destination IP Address table shows 209.165.200.235 with a count of 1.

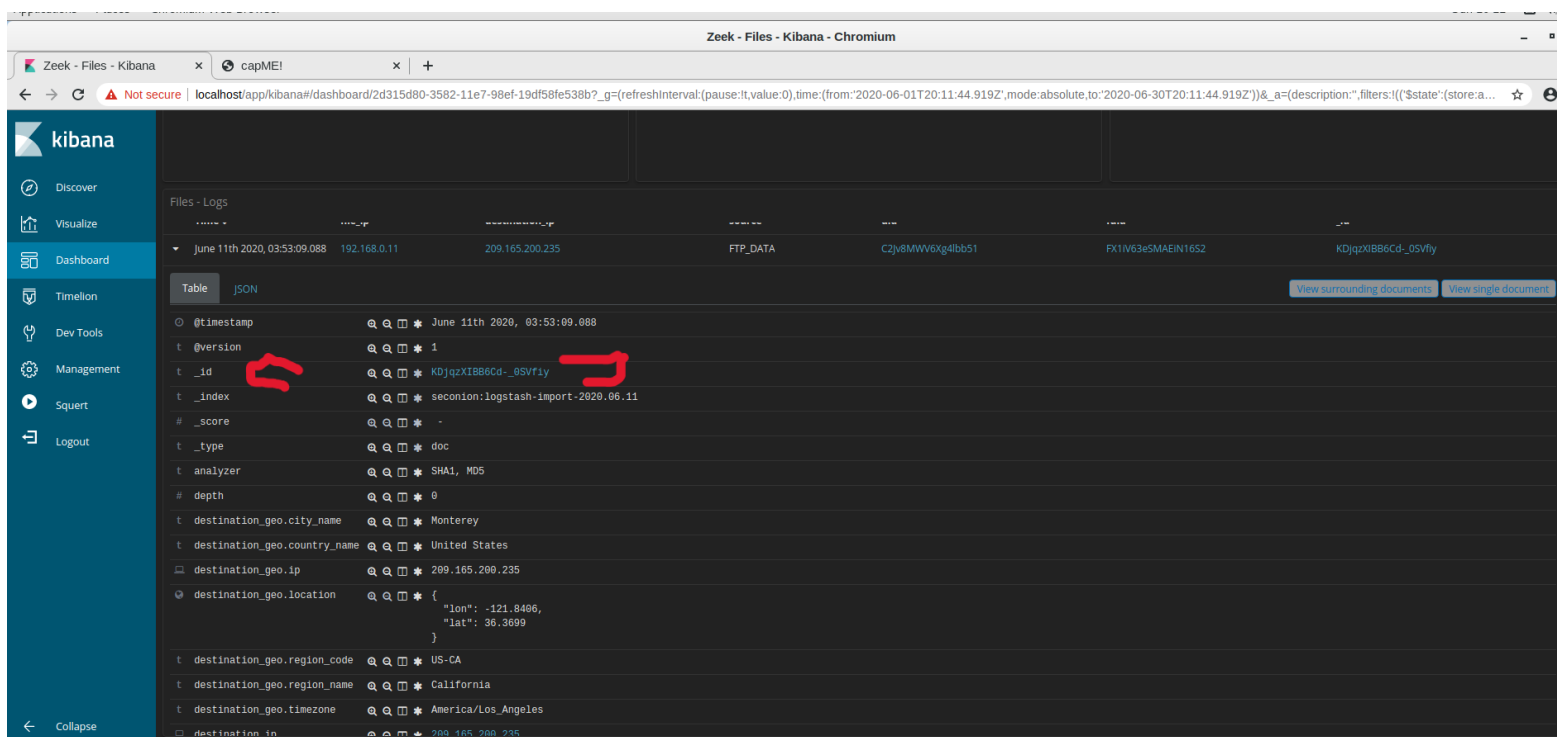
Source	Count	Bytes Seen	Count
FTP_DATA	1	102B	1

MIME Type	Count
text/plain	1

File IP Address	Count
192.168.0.11	1

IP Address	Count
209.165.200.235	1

I expanded the file log entry to locate the alert_id, which links directly to the session associated with the file transfer.

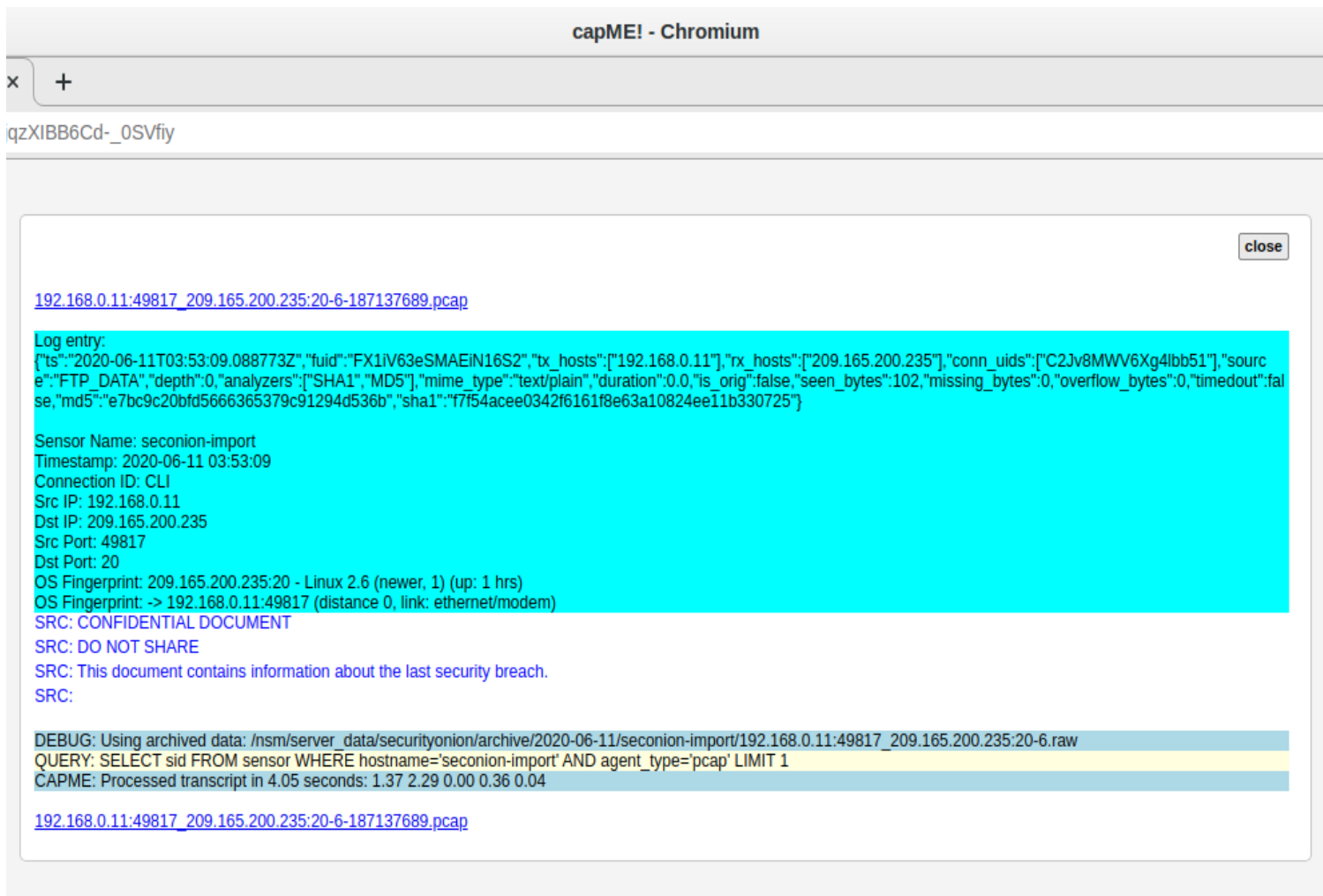


The screenshot shows the Zeek Files Kibana dashboard with a file log entry expanded. The entry is for a file transferred on June 11th, 2020, from 192.168.0.11 to 209.165.200.235. The file is named C2jv6MWV6g4lbb51 and has a MIME type of FTP_DATA. The expanded view shows the file's metadata, including the alert_id (KDjqzXIBB6Cd_0SVr1y) and the destination IP address (209.165.200.235). Red arrows point to the alert_id and the destination IP address.

File Log Entry
June 11th 2020, 03:53:09.088 192.168.0.11 209.165.200.235 FTP_DATA C2jv6MWV6g4lbb51 FX1W63e5MAEIN16S2 KDjqzXIBB6Cd_0SVr1y

Metadata	
@timestamp	June 11th 2020, 03:53:09.088
@version	1
_id	KDjqzXIBB6Cd_0SVr1y
_index	seconion:logstash-import-2020.06.11
_score	-
_type	doc
analyzer	SHA1, MD5
depth	0
destination_geo.city_name	Monterey
destination_geo.country_name	United States
destination_geo.ip	209.165.200.235
destination_geo.location	{ "lon": -121.8496, "lat": 36.3699 }
destination_geo.region_code	US-CA
destination_geo.region_name	California
destination_geo.timezone	America/Los_Angeles
destination_ip	209.165.200.235

I clicked the alert_id link to open the session in CapMe, where I was able to preview the actual content of the transferred file and confirm the nature of the exfiltrated data.



Confidential.txt file that was stolen contained information about the last security breach.

Mitigation Measures and Post-Incident Security Hardening

To prevent further unauthorized access, I recommend revoking and resetting all compromised credentials, particularly for affected user accounts. FTP services should be replaced with secure alternatives like SFTP to protect data in transit, and access to sensitive ports must be tightly controlled through firewall rules. Implementing multi-factor authentication (MFA) will further strengthen access security. Lastly, a thorough forensic review of the compromised host and surrounding systems is essential to identify and remove any hidden backdoors or persistence mechanisms.

Observations and Reflections

During this lab, I observed how a simple file transfer protocol (FTP) can be exploited to exfiltrate sensitive data. The attacker gained root access, read the contents of confidential.txt, and transferred it using valid credentials over an insecure channel.

Each step of the attack left behind evidence that could be tracked using security tools.

What I Learned

I learned how to:

- Identify and validate intrusion alerts using Sguil.
 - Analyze network traffic in Wireshark, including TCP stream reconstruction.
 - Correlate log data and detect file transfers in Kibana using Zeek logs.
 - Trace attacker activity using CapMe and interpret raw session data.
 - Understand how data exfiltration happens and how to detect and respond to it.
-

Skills Demonstrated

- Threat detection and alert validation using IDS rules.
 - Packet and protocol analysis using Wireshark.
 - Log correlation and protocol filtering in Kibana.
 - Session reconstruction and forensic review with CapMe.
 - Critical thinking and investigation workflow, simulating real SOC analyst tasks.
-

Conclusion

This lab taught me how to investigate a full intrusion cycle from alert detection to data exfiltration using real SOC tools. It mirrors real-world cybersecurity operations where analysts must correlate logs, analyze traffic, and act quickly to contain threats, making these skills directly applicable to practical CyberOps roles. Using the 5-tuple (source/destination IPs, ports, and protocol) was key to tracking the attacker's session, confirming file transfer paths, and linking log events across tools.